

Diseño de API

PyME Financing Platform

Documento 4 de 5 - Endpoints, permisos, validaciones, respuestas, errores y convenciones del backend.

1. Principios de la API

Principio	Aplicacion
Backend como autoridad	Toda autorizacion y validacion se ejecuta en API, no solo en frontend.
REST modular	Endpoints agrupados por recurso: auth, companies, applications, documents, risk, matches, products, rules, audit.
Respuestas consistentes	Usar estructura comun para datos, errores y paginacion.
Auditoria controlada	Auditar cambios importantes sin exponer secretos ni datos sensibles completos.
Swagger/OpenAPI	Documentar endpoints, payloads, respuestas y errores.

2. Convenciones

Base URL local: `http://localhost:3001/api`
Auth: Authorization: Bearer
Formato: JSON para datos; multipart/form-data para archivos
Paginacion: `?page=1&limit;=20`
Filtros: `?status=documents_pending&companyId;=...`

2.1 Respuesta exitosa

```
{
  "success": true,
  "data": { ... },
  "meta": { "page": 1, "limit": 20, "total": 100 }
}
```

2.2 Respuesta de error

```
{
  "success": false,
  "error": {
    "code": "VALIDATION_ERROR",
    "message": "Datos incompletos para calcular riesgo.",
    "details": ["has_existing_debt debe estar confirmado"]
  }
}
```

3. Endpoints de autenticacion

Metodo	Endpoint	Rol	Proposito	Validaciones
POST	/auth/login	Publico	Iniciar sesion.	Usuario activo, password valido, respuesta sin revelar detalle de fallo.
GET	/auth/me	Autenticado	Consultar usuario actual.	JWT valido.
POST	/auth/logout	Autenticado	Cerrar sesion logica si se implementa.	JWT valido; opcional registrar auditoria.

4. Usuarios y roles

Metodo	Endpoint	Rol	Proposito	Validaciones
GET	/users	internal_operator	Listar usuarios.	Filtrar por rol/activo; no exponer password_hash.
POST	/users	internal_operator	Crear usuario.	email unico, rol existente, password hasheado.
PATCH	/users/:id	internal_operator	Editar usuario o desactivar.	No permitir editar password_hash directo.
GET	/roles	internal_operator	Consultar roles semilla.	Solo roles activos.

5. Empresas

Metodo	Endpoint	Rol	Proposito	Validaciones
GET	/companies	Ambos	Listar empresas.	internal_operator ve todas; applicant solo applicant_user_id propio.
POST	/companies	Ambos	Crear empresa.	RFC unico, business_type, montos >= 0, ownership correcto.
GET	/companies/:id	Ambos	Ver detalle.	Validar propiedad si applicant.
PATCH	/companies/:id	Ambos	Editar empresa.	Validar propiedad; no duplicar RFC.
GET	/companies/:id/applications	Ambos	Listar solicitudes de empresa.	Validar acceso a la empresa.

6. Solicitudes

Metodo	Endpoint	Rol	Proposito	Validaciones
GET	/applications	Ambos	Listar solicitudes.	internal_operator todas; applicant solo propias.
POST	/applications	Ambos	Crear solicitud.	company_id accesible, monto > 0, plazo > 0, necesidad definida.
GET	/applications/:id	Ambos	Detalle de solicitud/expediente base.	Validar acceso por empresa.
PATCH	/applications/:id	Ambos	Editar datos no criticos.	No permitir cambios criticos si closed.
PATCH	/applications/:id/status	internal_operator	Cambiar estado.	Solo transiciones validas; crear status_history.

7. Documentos

Metodo	Endpoint	Rol	Proposito	Validaciones
GET	/document-requirements	Ambos	Consultar requisitos documentales.	Filtrar por activos y aplicabilidad.
POST	/document-requirements	internal_operator	Crear requisito.	name unico, applies_to valido.
PATCH	/document-requirements/:id	internal_operator	Editar/desactivar requisito.	No borrar si ya se uso.
GET	/applications/:id/documents	Ambos	Ver documentos de solicitud.	Validar acceso a solicitud.
POST	/documents/:id/upload	Ambos	Subir archivo local.	Permiso, tipo, tamano, nombre seguro, hash.
PATCH	/documents/:id/review	internal_operator	Aprobar/rechazar/no aplica.	reviewed_by_user_id, reviewed_at, notas si rejected.

Metodo	Endpoint	Rol	Proposito	Validaciones
GET	/documents/:id/download	Ambos	Descargar archivo.	Validar permiso; no exponer rutas internas.

8. Analisis de riesgo y matching

Metodo	Endpoint	Rol	Proposito	Validaciones
GET	/applications/:id/risk-assessments	Ambos	Listar historial de riesgo.	Validar acceso; ordenar por calculated_at desc.
POST	/applications/:id/risk-assessments	internal_operator	Calcular nuevo riesgo.	Precondiciones completas; input_snapshot obligatorio.
GET	/risk-assessments/:id/matches	Ambos	Ver recomendaciones de un analisis.	Validar acceso a solicitud padre.
POST	/risk-assessments/:id/matches	internal_operator	Generar matching.	Productos activos, reglas activas, no duplicar producto por analisis.

9. Productos financieros y reglas

Metodo	Endpoint	Rol	Proposito	Validaciones
GET	/financial-products	internal_operator	Listar productos.	Filtrar activos/inactivos.
POST	/financial-products	internal_operator	Crear producto.	name unico, rangos validos, tasa >= 0.
PATCH	/financial-products/:id	internal_operator	Editar/desactivar producto.	No borrar si hay historial.
GET	/financial-products/:id/rules	internal_operator	Listar reglas.	Producto existente.
POST	/product-rules	internal_operator	Crear regla.	rule_field, operator, condition_value y score_weight validos.
PATCH	/product-rules/:id	internal_operator	Editar/desactivar regla.	Si operator between, condition_value_to requerido.

10. Auditoria

Metodo	Endpoint	Rol	Proposito	Validaciones
GET	/audit-logs	internal_operator	Consultar bitacora.	Filtrar por usuario, entidad, fecha; no exponer secretos.
GET	/applications/:id/status-history	Ambos	Consultar historial de estados.	applicant solo sus solicitudes.

11. Codigos de error sugeridos

Codigo	Uso
UNAUTHORIZED	JWT ausente, invalido o expirado.
FORBIDDEN	Usuario autenticado sin permiso para recurso o accion.
NOT_FOUND	Recurso inexistente o no visible para el usuario.
VALIDATION_ERROR	Payload invalido o faltan datos obligatorios.
INVALID_STATE_TRANSITION	Cambio de estado no permitido.

Codigo	Uso
RISK_PRECONDITION_FAILED	No se puede calcular riesgo por datos incompletos.
FILE_VALIDATION_ERROR	Archivo no permitido, excede tamaño o metadatos inválidos.
DUPLICATE_RESOURCE	RFC, email, producto o documento ya existe.

Anexo de Actualización

PyME Financing Platform

Documento base conservado: Diseño de API

Este anexo no reemplaza ni resume el documento base. El contenido original se conserva íntegro. Las reglas de este anexo se agregan al diseño y prevalecen cuando una regla anterior sea ambigua o use lenguaje de sugerencia.

A. Decisiones confirmadas para todos los documentos

Decisión	Instrucción obligatoria
Registro de applicant	El applicant debe poder crear su propia cuenta desde una ruta pública usando, como mínimo, fullName, email y password. El sistema debe asignar el rol applicant automáticamente.
Resultado visible para applicant	El applicant no debe ver el análisis interno completo, risk_score, pesos de reglas, DSCR detallado, audit_logs ni comparación interna de productos. Solo debe ver la decisión final publicada por el operador.
Operación interna	El internal_operator debe ver risk_assessments, application_matches, razones internas, porcentajes, indicadores financieros y debe crear/publicar la decisión final.
Corrección de necesidad	El internal_operator debe poder validar o corregir la necesidad declarada por el applicant mediante validated_need_type antes de generar matching o decisión final.
Documentos rechazados	Cuando el applicant suba nuevamente un documento rechazado, el sistema debe reemplazar el archivo en el mismo application_document, actualizar metadatos, cambiar status a uploaded y registrar audit_log.
Auditoría	El sistema debe auditar solo acciones sensibles; no debe registrar absolutamente todos los cambios ni guardar secretos, tokens, password_hash o contenido de documentos.

B. Regla de redacción para implementación

Toda frase del documento base que use “recomendado”, “sugerido”, “podría” o “si se implementa” debe interpretarse como instrucción obligatoria cuando describa una regla del MVP, una validación de seguridad, una entidad de base de datos, un endpoint crítico, una transición de estado o una prueba mínima.

C. Endpoints agregados

Método	Endpoint	Rol	Regla
POST	/auth/register	Público	Crea applicant. Validar email único, password, fullName y asignar rol applicant.
PATCH	/applications/:id/validated-need-type	internal_operator	Guarda validated_need_type, notas, usuario y fecha. Audita validate_need_type.
POST	/applications/:id/decision	internal_operator	Crea application_decision ligada a risk_assessment_id y opcional selected_match_id.
PATCH	/application-decisions/:id/publish	internal_operator	Publica decisión, asigna published_at y cambia solicitud a decision_published.
GET	/applications/:id/decision	internal_operator/applicant	Operador ve completa. Applicant solo ve publicada y propia.

Reglas de respuesta

- El endpoint del applicant no debe devolver risk_score, risk_level interno, DSCR detallado, score_weight, reglas ni internal_notes.
- El endpoint del operador debe devolver análisis interno, matches, decisión, notas internas y trazabilidad.
- Los endpoints de decisión deben usar errores VALIDATION_ERROR, FORBIDDEN, NOT_FOUND, INVALID_STATE_TRANSITION y RISK_PRECONDITION_FAILED cuando aplique.